

Compliance and Governance: GRC Layer with Cloud Scanner Evidence

Objective

Create a central GRC layer that converts technical findings into control status, risk visibility, remediation ownership, and audit-ready evidence. CloudGuard acts as a technical evidence source for cloud, Kubernetes, and IaC controls.

Highlights

GRC function	Policies, controls, risks, audits, exceptions, remediation, and evidence in one governance view.
Evidence sources	LogManthan, infrastructure scanners, asset inventory, SAST, DAST/Burp, Keycloak/IAM, DPDP inputs, and CloudGuard cloud scanners.
Cloud scanner role	AWS, GCP, Kubernetes, and IaC scan results are normalized into control evidence.
Control mapping	Findings map to DPDP, ISO 27001, CIS, NIST, OWASP, Kubernetes benchmark, and internal policies.

Technical Summary

The architecture uses a connector-based evidence pipeline. Each scanner or source system sends normalized evidence to an ingestion API. The ingestion layer validates the payload, stores raw artifacts in object storage, stores metadata and mappings in PostgreSQL, and updates the GRC dashboard. Scanner jobs remain decoupled from the portal through worker containers so heavy scans do not block the dashboard.

Setup View

Public routes	app.cloudscanner.com for dashboard, api.cloudscanner.com for APIs, ingest.cloudscanner.com for evidence ingestion.
Runtime	Docker Compose stack managed through Dokploy on a VM for the PoC.
Core services	Backend/API, PostgreSQL, object storage, scheduler worker, scan worker, evidence connector.
Expected output	Compliance dashboard, control status, evidence trail, remediation owner, audit report, and executive summary.

One-line summary: The GRC layer gives leadership, auditors, and engineering teams one common view of compliance posture by converting scanner outputs and manual evidence into control-mapped, traceable, and actionable governance records.